Current implementation and evidence

Evidence date: 5 September 2026. Branch `codex/migration-control-plane-release-2026-08-29`; commit `a05a41ef66cd5d98fd69ae3df18225795f912232`. The workspace contains substantial pre-existing changes. Findings refer to the inspected working tree, not a clean release commit. Baseline and 24 source hashes

This is a targeted composition design review using fresh module-source inspection, a new static inventory and isolated behavior probes, together with the earlier Astra platform review. It is not a second exhaustive security audit. The earlier review's 456 focused tests and typecheck results are historical evidence, not reruns in this design assignment.

Implementation map

Area	Current truth	Status / treatment	Source
Canonical module vocabulary	19 slugs; dashboard, settings and administration are core. HRIS and assisted work have no canonical module slug.	Implemented; keep stable IDs and add explicit mappings.	Contract, captured catalogue.
Catalogue and dependencies	Localized descriptions, routes and required/recommended dependencies exist. Route matching uses longest applicable prefix.	Reuse; validate ownership and dependency semantics.	Catalogue.
Legacy intent	`Organization.requestedModules` is the persisted selection source; empty intent derives broad legacy grants.	Partial; it is not a subscription or revisioned configuration.	Schema, derivation.
Evaluator	Supports observe/enforce, statuses, intent, dependencies and wildcard diagnostics. Temporal validity is not evaluated; dependency presence is weaker than effective dependency availability.	Extend with explicit contracts and focused regressions.	Evaluator.
Enforcement	Default contract says observe, while protected actions default supplied module guards to enforce and API helper explicitly enforces. Result always reports `hardEnforcementEnabled:false`.	Inconsistent reporting; do not infer global non-enforcement.	Action guard, API guard.
Activation	Real action/service exist, resolve required dependencies, update intent in a serializable transaction and audit the outcome. Action uses a server-derived organization, known setting permission and fresh authentication.	Implemented, narrower than full provisioning; reuse.	Action, service.
Activation interface	EN/FR button, confirmation and password step-up recovery exist.	Extend to impact preview and typed setup states.	Button.
Control-center language	Page says “Nothing is hard-blocked yet.”	Stale relative to enforcing callers; retire this blanket statement in implementation.	Page.
Session hints / navigation	Session contains a hardcoded `modulesEnabled` list with `admin`; canonical slug is administration. Sidebar is permission-driven.	Consolidate presentation around server-produced effective capabilities; never use the hints as authority.	Session, sidebar configuration.

Area	Current truth	Status / treatment	Source
Subscription, packages and grants	No durable module/subscription/entitlement model matching the inspected schema search. Payment-provider models elsewhere do not establish SaaS billing implementation.	Proposed work; name search is corroborated by inspected module persistence, not proof no adjacent integration exists.	Schema discovery, module services.
Surface inventory	Current scanner includes report/export evidence and API guard inventory.	Reuse and expand; current classifications overlap.	Fresh inventory, scanner.
Financial/domain controls	Existing posting, period, AP, payroll, event and offline services provide substantial reusable foundations.	Retain their authoritative writes; add composition adapters. No new accounting engine.	Posting, AP, prior traces.
Native approval register	September 3 blueprint and guide exist. Provider folder contains a README and local file simulator. No general register persistence was found in the inspected schema.	Proposed register; simulator is not authenticated authority.	Blueprint, provider contract.
X1	Draft forms and version/digest manifests exist; actual decisions and authenticated technical evidence remain required in the earlier current review.	Preserve the real gate. This run does not issue approval or revalidate X1.	Astra user actions, X1 artifact manifest.

Dependency inconsistencies worth correcting

Reconciliation currently requires finance and accounting; close requires accounting and recommends reconciliation. Preserve those edges in the first slice. Payroll merely recommends accounting, although posting invariants need an explicit mandatory capability contract. Cash drawer inherits `dependenciesFor("pos")` and compliance inherits `dependenciesFor("accounting")`; these are implicit reuse decisions that obscure each module's real requirements. Purchasing can buy services without stock; requiring inventory for every purchase would also be wrong. The target must express capability- and operation-specific prerequisites, not flatten all business variations into a single blanket dependency list.

Fresh isolated behavior probes

The actual current TypeScript was transpiled in memory with controlled imports and an in-memory synthetic persistence stub. No real tenant or database was used. These expose service behavior; surrounding guards can restrict reachability. Complete results and method

Probe	Observed behavior	Consequence and proposed remedy
C01	`explicitEntitlements: []` falls back to legacy grants.	Explicitly migrated-empty must differ from missing legacy data.
C02	An expired trial grant remains allowed.	Validate status plus well-formed start/end bounds using server time.
C03	POS accepts a present but suspended sales dependency.	Check dependency capability availability for the requested operation.
C04	A read-only inventory API read is denied by the surface allowlist.	Authorize the operation's read semantics consistently across transport types.

Probe	Observed behavior	Consequence and proposed remedy
C05	Enforcing deny still reports enforcement false and observe-oriented language.	Return actual policy mode and a truthful reason; separate shadow result from enforced outcome.
C06	A missing organization becomes legacy defaults inside the module service.	Require a resolved existing organization at this boundary. This is not proof an outer API exposes missing tenants.
C07	Enabling reconciliation for empty legacy intent changes inferred grants from 19 to 6, losing 13 other inferred grants.	Snapshot/reconcile existing rights before converting to explicit selection; preview the entire access difference. Do not ship a silent narrowing migration.

Duplicate grant handling also needs a deterministic policy: current map construction effectively permits last-entry wins. The target uses a canonical resolver that rejects ambiguous overlapping grants unless an explicit precedence rule applies. This issue was inspected, not separately reproduced by a fresh current-code probe.

Fresh inventory and its limits

415 surface records were generated in isolated report mode: 371 mapped, 5 unmapped, 79 missing-permission classifications, 77 dashboard-only-risk classifications and 6 review-required classifications. Counts overlap and include evidence records; **they are not counts of distinct exploitable vulnerabilities**. The scanner contains 146 action records, 129 pages, 83 navigation entries and additional API/layout/report/export records. Complete details are in the JSON.

The July 14 proposal and July 18 status are historical. Current August activation work and the current scanner supersede assertions that activation or report/export inventory are wholly absent. The old module program register is not promoted by this design run. Source-derived gaps, implementation evidence and actual release authorization remain separate.

The existing graph manifest now references this `Focused projects/stoquify` checkout. This corrects the older report's provenance concern about another directory. Path agreement alone does not prove graph freshness. `graph_actions.json` contains 1,044 nodes and `graph_components.json` 1,173. Useful examples include component node `dashboard_sidebar_tsx`, community 60, and action-test node `tests_inventorylossreadactions_test_moduledecision`, community 44. They locate sidebar and entitlement-test relationships; current source, not inferred graph edges, substantiates this report. Captured graph provenance

Review coverage and multidisciplinary assessment

The following are analytical perspectives applied by this review, not independent professional sign-offs.

Responsibility	Assessment / material finding
Platform architect	Retain one application; make module boundaries and ownership explicit.
Backend/domain engineer	Guard reusable domain operations; avoid new competing writers.
Database/migration architect	Add revisioned state and scoped uniqueness; preserve legacy rights and unknown legacy values during reconciliation.
Security/IAM/privacy architect	Resolve tenant and actor server-side; temporal grants, field scopes and private evidence are distinct concerns.
Frontend/design-system engineer	Adapt existing buttons, table conventions and shell; remove duplicated capability truth.

Responsibility	Assessment / material finding
Workflow/accessibility/localization designer	Clear next actions, distinct states, EN/FR; prototype keyboard/mobile checked, screen-reader certification not performed.
Product strategist	Sell outcomes; include integrity dependencies and explain optional specialist workspaces.
Quality/release lead	Require focused negative/transition evidence and scoped environment promotion.
SRE/DevSecOps engineer	Durable provisioning, useful telemetry, provider reconciliation and recovery exercises precede operational claims.
SaaS packaging/billing/customer success	Separate offers, subscriptions, entitlement, tenant choice and employee access; supply a supportable change history.
Finance/internal controls	Preserve source-linked posting, maker/checker and period controls regardless of paid workspace selection.
Statutory/country packs	Reviewed country rules attach to activity; no tax/legal certification inferred from code.
Audit/records	Retain versioned evidence and revocation; a hash proves content identity, not signer authority.
POS/inventory/offline	Capture, valuation and replay obligations survive configuration changes through explicit continuation rules.
Purchasing/AP	Separate goods/service receipts and payable ownership from payment settlement evidence.
HRIS/payroll	Explicit HRIS source boundary, immutable approved inputs, narrow employee access and country scope.
Payments/reconciliation	First journey; retain current dependencies and provider evidence without duplicate settlement posting.
Accounting close/reporting	Integrity kernel owns journals; close evidence invalidates when authoritative sources change.
Analytics/data governance	Source-scoped projections with freshness; fix mutable-cost COGS before relying on historical metrics.
AI agents	Assist only through known tools and existing user/domain policy; no automatic self-approval.
APIs/events/import-export	Register transport-independent operations; tenant-scoped deduplication, safe exports and event compatibility.
Rollout/support	Pilot a named cohort, explain restrictions, preserve rollback and retained-history access.

Source coverage is selective: fresh full reads concentrated on module contracts/catalogue/evaluator/action/button, with targeted guards, navigation, schema, workflow imports/events, approval status and prior findings. Application routes, components, hooks, types, localization, CI/migrations and infrastructure receive context from inventories and the prior Astra review plus targeted reads. No claim is made that every line, hook or migration was re-audited here. Third-party code execution is not applicable to the initial implementation; its trust model is explicitly deferred.

Astra findings carried forward

For a pilot handling private financial records, require resolved private-file access/storage exposure, current access enforcement regressions, deployment dependency reproducibility, applicable X1 evidence, named operators and restore/monitoring evidence. The earlier review's session/middleware/private-response fixes are investments to retain and retest when changed. They were not modified here.

Silent logging, process-local rate limits and timeout-versus-cancellation are relevant operational risks for exports/providers/agents; sequence them with the workloads actually included. Mutable item-cost COGS affects financial analytics truth and must be corrected before that metric is promoted. Broad market-network/marketplace ambitions and unrelated UI normalization are outside the first module slice. Prior findings

This proposal consolidates evidence collection through a source-bound run and reuses existing gates. It does not create a new approval requirement for every configuration edit or bypass approvals needed for actual product, security or statutory decisions.